Universidad del Rosario | Escuela de Ingeniería, Ciencia y Tecnología | MACC Matemáticas Aplicadas y Ciencias de la Computación | HINNT Hub de INNovación y Transferencia

Security in Enterprise Architecture



Ricardo Duitama

Profesional Ciberseguridad - MACC
Profesor catedra

ricardo.duitama@urosario.edu.co

@MACC_URosario @MACC.URosario macc_ur

DEFINITION THE ENTERPRISE ARCHITECTURE (EA)

La arquitectura empresarial es una practica en la gestión empresarial y en la de tecnologías de la información (TI). Está enfocada en **mejorar el desempeño** de una empresa al entenderla en términos integrales desde su **perspectiva estratégica**, desde las **prácticas** y **procesos organizacionales**, y a partir de las **TI** como habilitadoras de la entidad.

La arquitectura empresarial permite **direccionar iniciativas** con una visión completa de una empresa, de tal manera que se **reduzcan los costos** y los **riesgos**, y que se genere **mayor agilidad en la entrega de servicios** de TI que habiliten los trámites, los procesos y las funciones en el campo institucional e incluso de forma trasversal entre entidades de uno o más sectores.

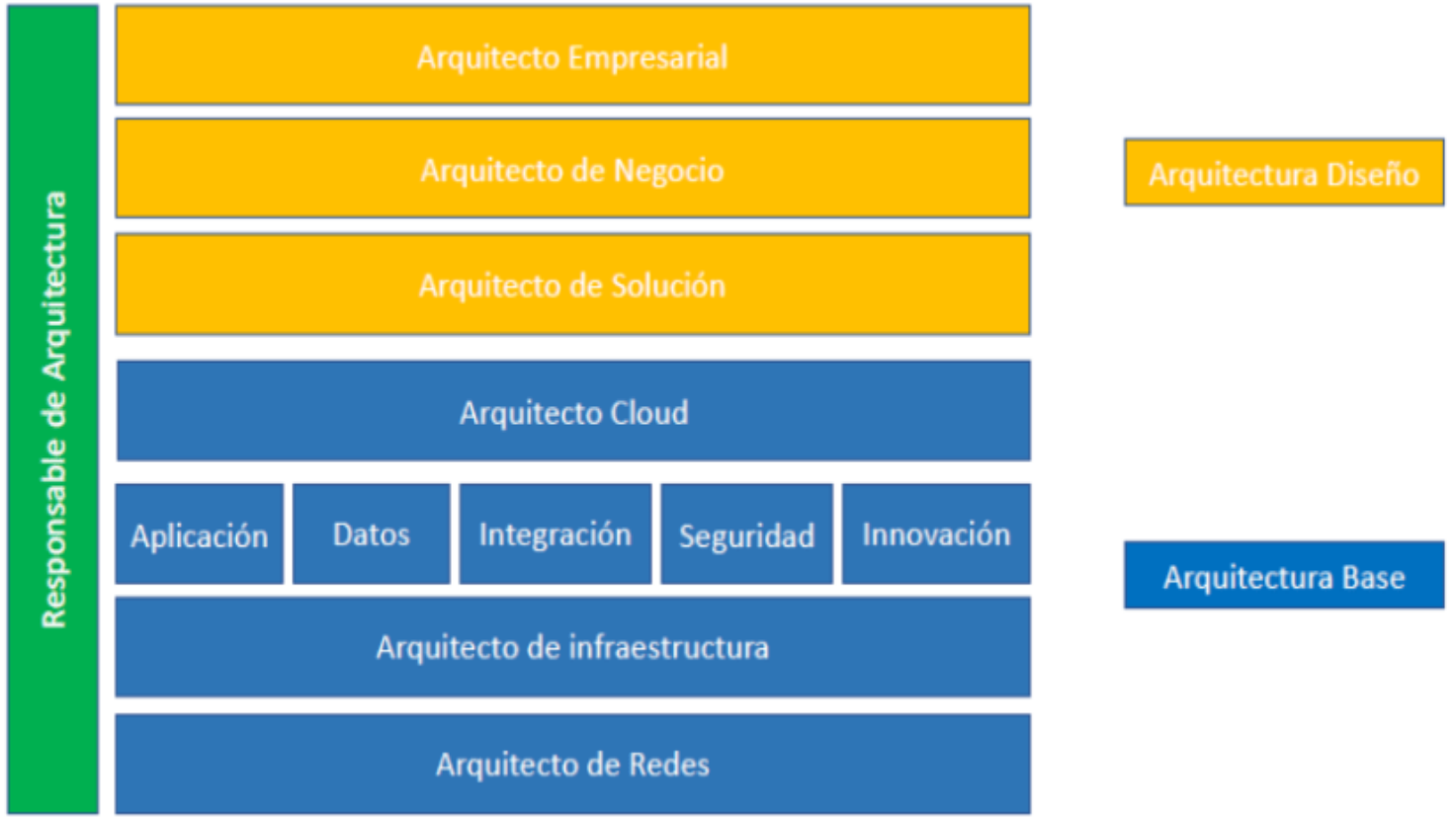


Fuente: https://albatian.com/es/blog/la-arquitectura-empresarial-necesaria-para-no-ir-a-ciegas-en-cualquier-innovacion-y-transformacion-empresarial/

ROLES IN THE ENTERPRISE ARCHITECTURE (EA)

Al realizar o tener una arquitectura empresarial se puede revisar que los procesos, funciones y tecnología de la información están afinados y armonizados.

Esta visión integral de las empresas requiere formar un rol de arquitecto, que tenga la capacidad de entender la organización desde diferentes puntos, de tal manera que genere un entendimiento desde la posición de la gerencia, desde las unidades operacionales, las técnicas y las administrativas; al final, se obtiene una comprensión completa de las capacidades, necesidades y requerimientos de la entidad.



Fuente: https://elementi.me/roles-en-arquitectura-empresarial/

UNDERSTANDING THE ENTERPRISE ARCHITECTURE (EA)

- An EA is both a result and a process.

- From a process perspective, it is a well-defined practice for performing:
  - analysis
  - design
  - planning and
  - implementation of **technology**

- EA supports planning and decision making through documentation and information that provides an abstract view of an enterprise at various levels of scope and detail.

- EA provides a framework to define:
  - business requirements
  - business rules and
  - business cases that will lead the organization to successfully accomplish its **mission, vision, and purpose**.

UNDERSTANDING THE ENTERPRISE ARCHITECTURE (EA)

- The purpose of EA is to optimize **fragmented legacy processes** into an integrated environment that is **responsive to change** and supports **delivery of the business strategy**.

- A mature and comprehensive implementation of EA could allow an organization to adopt potentially controversial solutions like:

    - consumerization of IT
    - internet of things (IoT) and
    - bring your own device (BYOD)

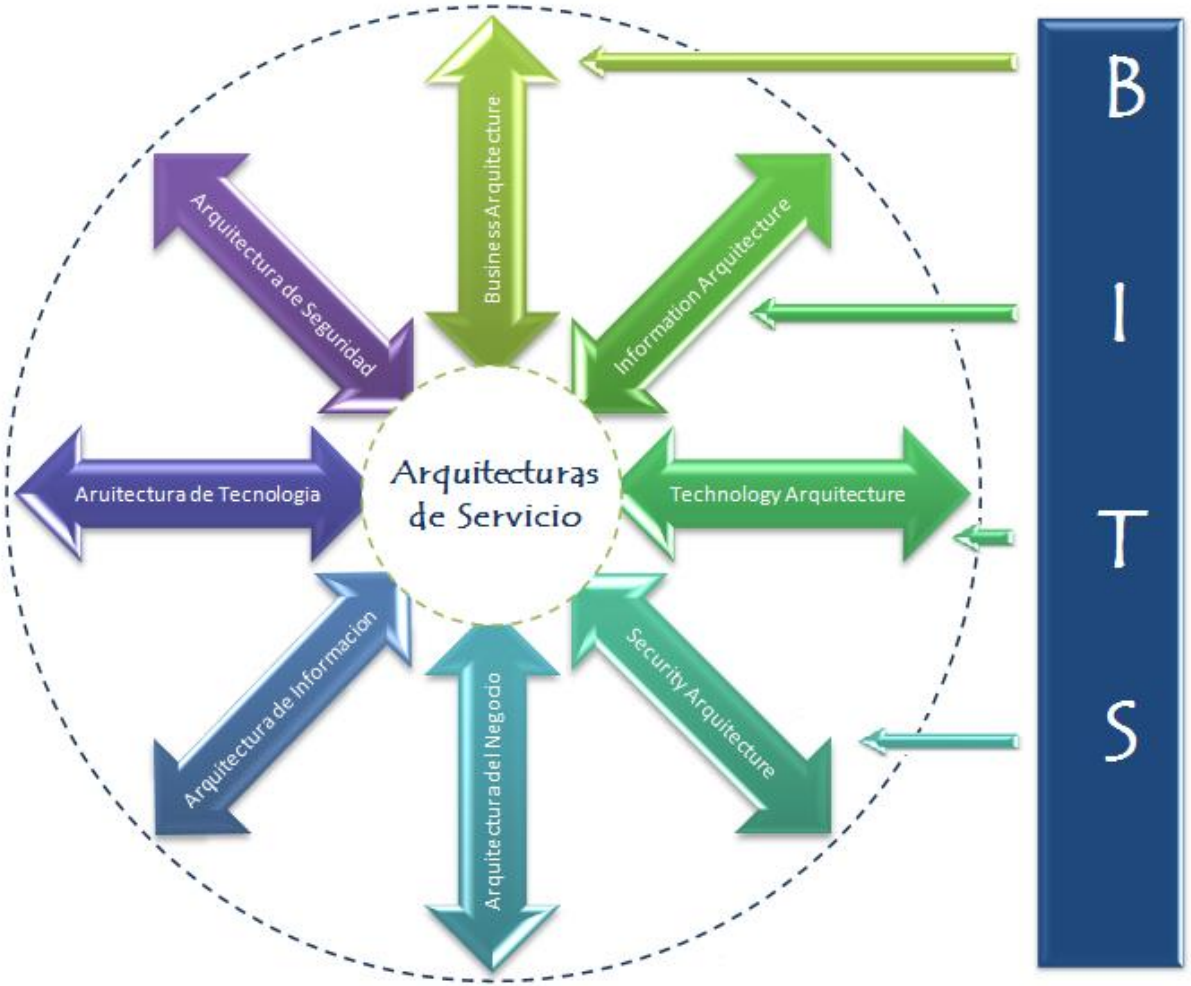
- Various approaches for developing EA exist. Some options are more flexible than others, and each option applies differently depending upon the **type and objectives** of the organization.

- The framework an organization selects is important because EA, among other considerations, influences **change management, infrastructure management, security controls, and application development**.

ENTERPRISE INFORMATION SECURITY ARCHITECTURE (EISA)

Es la práctica de aplicar un método riguroso y comprensivo para describir una estructura actual y/o futura y el comportamiento de los procesos de seguridad de una organización, sistemas de seguridad de información y subunidades de personal y organizativas, para que se alineen con las metas comunes de la organización y la dirección estratégica. Aunque a menudo se asocie estrictamente con tecnologías para la seguridad de la información, se relaciona en términos más generales con la práctica de seguridad de optimización del negocio, donde dirige la arquitectura de seguridad del negocio, la realización de gestiones y también la arquitectura de procesos de seguridad.

Desde su publicación, la arquitectura de seguridad ha pasado de ser un silo basado en arquitectura a una solución enfocada a la empresa que incorpora negocio, información y tecnología. La figura siguiente representa una vista unidimensional de la arquitectura de la empresa como una arquitectura orientada a servicios. También refleja la nueva suma a la familia de la arquitectura empresarial llamada "Seguridad" *(Security)*. La arquitectura de negocio *(Business)*, de información *(Information)* y de tecnología *(Technology)* suelen ser llamadas BIT para acortar. Ahora con la seguridad como parte de la familia de arquitecturas, se ha convertido en BITS.

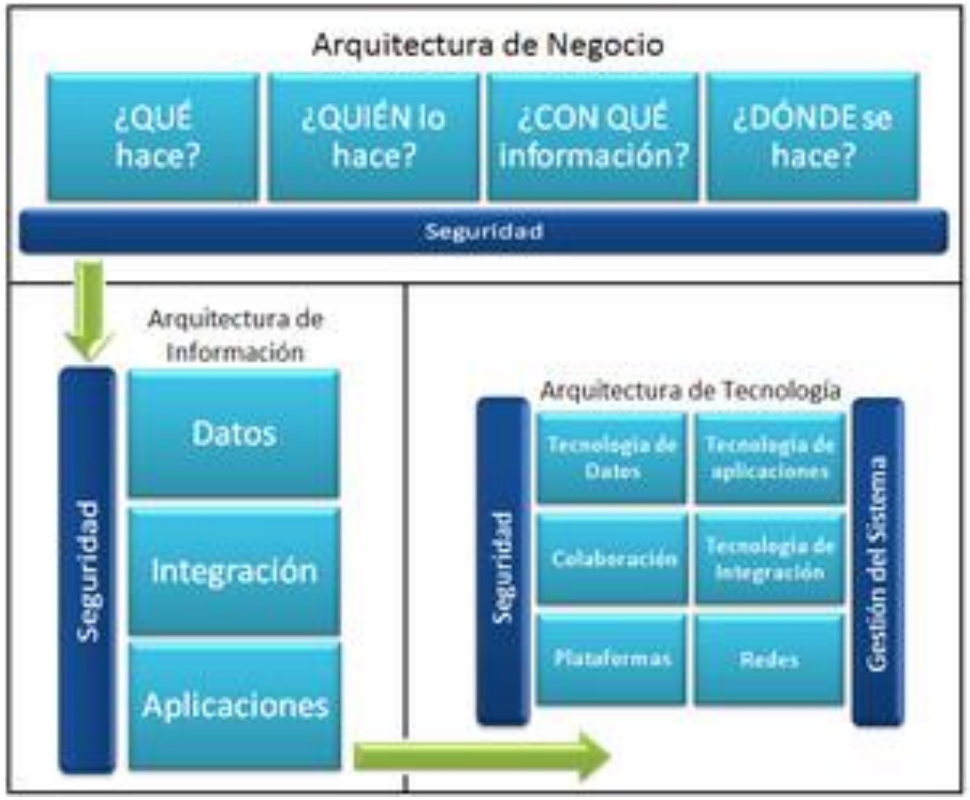


https://commons.wikimedia.org/wiki/File:BITS-es.PNG

EISA – CRITICAL POINTS

- Un gran componente de la arquitectura de seguridad es que no existe una arquitectura de seguridad independiente. Es una 'preocupación transversal'. Eso significa que hay un aspecto de seguridad en cada dominio de arquitectura empresarial. Por ejemplo: en el contexto de su negocio, cuando piense en su software empresarial, tendrá un componente de seguridad. Eso podría considerarse parte de su arquitectura de seguridad y operaciones de seguridad.
- El marco de arquitectura de seguridad de información de la empresa es sólo un subconjunto de los marcos de Arquitectura de Empresa





THE ZACHMAN FRAMEWORK

The Zachman Framework for Enterprise Architecture

The Zachman Framework is an ontology providing a **classification system** that produces a working model of entities and interactions that create an **agreed-upon vocabulary** for exchanging information when specified.

The Zachman Framework typically is depicted as a bounded 6 x 6 matrix with the Communication Interrogatives as Columns and the Reification Transformations as Rows.



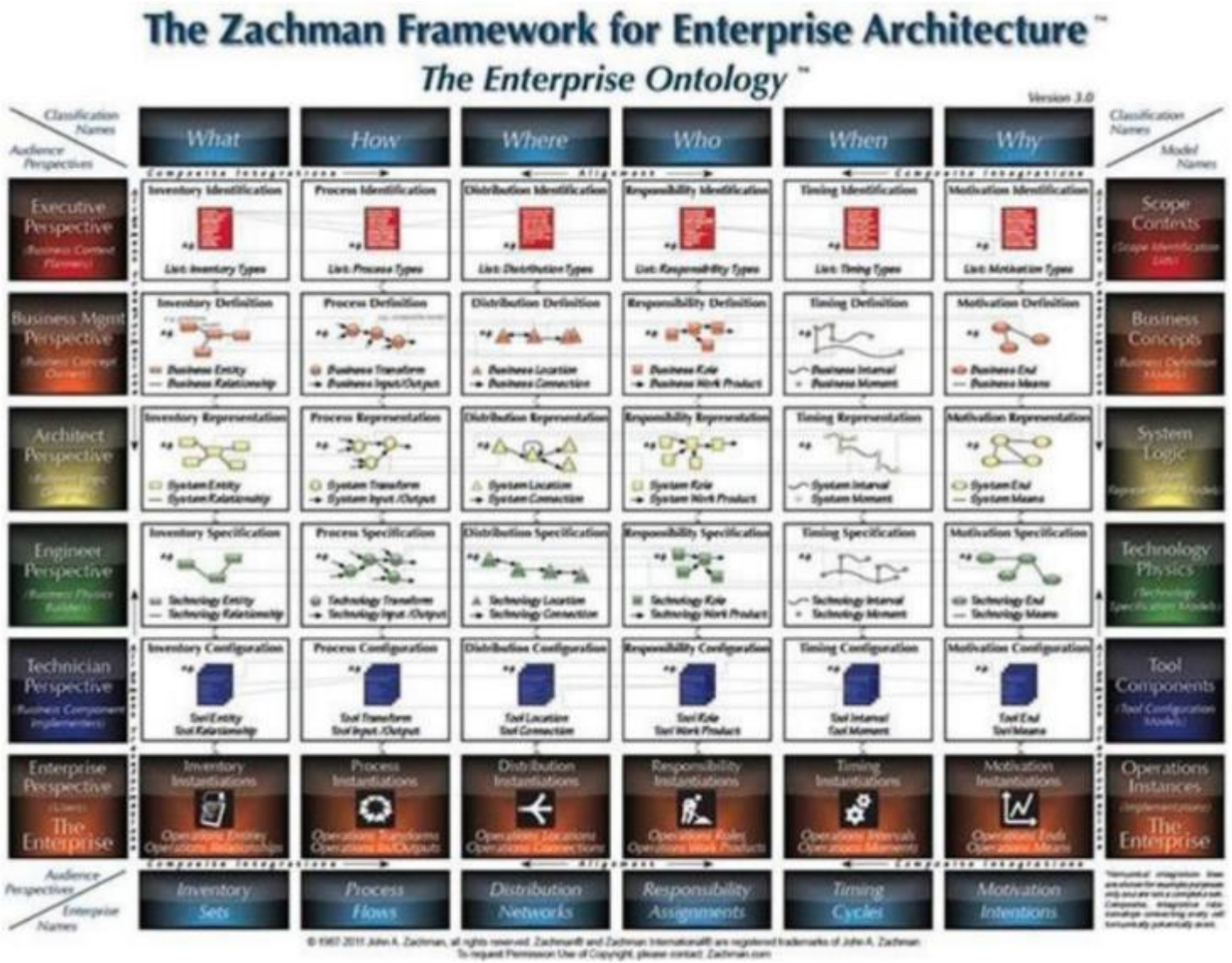
THE ZACHMAN FRAMEWORK

The Framework classifications are represented by the Cells, that is, the **intersection** between the Interrogatives and the Transformations.

This matrix would necessarily constitute the **total set of descriptive representations** that are relevant for an enterprise.

Because of **complexity** and **detail**, the Zachman Framework is a tool best suited for large enterprise environments.

Smaller organizations with appropriate resources can use some **portions** of the matrix.



The Zachman Framework for Enterprise Architecture™

The Enterprise Ontology ™

Version 3.0



© 1987-2011 John A. Zachman, all rights reserved. Zachman® and Zachman International® are registered trademarks of John A. Zachman
To request Permission Use of Copyright, please contact: Zachman.com

SHERWOOD APPLIED BUSINESS SECURITY ARCHITECTURE (SABSA)

SABSA comprises a series of **integrated frameworks, models, methods, and processes** used independently, or as a holistic integrated enterprise solution, including

- Business Requirements Engineering Framework (Attributes Profiling)
- Risk and Opportunity Management Framework
- Policy Architecture Framework
- Security Services–Oriented Architecture Framework
- Governance Framework
- Security Domain Framework
- Through-life Security Service Management and Performance Management Framework

SABSA Matrix is **similar** to the Zachman Framework.

SABSA is different from Zachman's Framework because of the focus on **integrating security in the EA**.

	ASSETS (What)	MOTIVATION (Why)	PROCESS (How)	PEOPLE (Who)	LOCATION (Where)	TIME (When)
CONTEXTUAL ARCHITECTURE	Business Decisions	Business Risk	Business Processes	Business Governance	Business Geography	Business Time Dependence
	Taxonomy of Business Assets, including Goals & Objectives	Opportunities & Threats Inventory	Inventory of Operational Processes	Organisational Structure & the Extended Enterprise	Inventory of Buildings, Sites, Territories, Jurisdictions, etc.	Time dependencies of business objectives
CONCEPTUAL ARCHITECTURE	Business Knowledge & Risk Strategy	Risk Management Objectives	Strategies for Process Assurance	Roles & Responsibilities	Domain Framework	Time Management Framework
	Business Attributes Profile	Enablement & Control Objectives; Policy Architecture	Process Mapping Framework; Architectural Strategies for ICT	Owners, Custodians and Users; Service Providers & Customers	Security Domain Concepts & Framework	Through-Life Risk Management Framework
LOGICAL ARCHITECTURE	Information Assets	Risk Management Policies	Process Maps & Services	Entity & Trust Framework	Domain Maps	Calendar & Timetable
	Inventory of Information Assets	Domain Policies	Information Flows; Functional Transformations; Service Oriented Architecture	Entity Schema; Trust Models; Privilege Profiles	Domain Definitions; Inter-domain associations & interactions	Start Times, Lifetimes & Deadlines
PHYSICAL ARCHITECTURE	Data Assets	Risk Management Practices	Process Mechanisms	Human Interface	ICT Infrastructure	Management Schedule
	Data Dictionary & Data Inventory	Risk Management Rules & Procedures	Applications; Middleware; Systems; Security Mechanisms	User Interface to ICT Systems; Access Control Systems	Host Platforms, Layout & Networks	Timing & Sequencing of Processes and Sessions
COMPONENT ARCHITECTURE	ICT Components	Risk Management Tools & Standards	Process Tools & Standards	Personnel Man'ment Tools & Standards	Locator Tools & Standards	Step Timing & Sequencing Tools
	ICT Products, including Data Repositories and Processors	Risk Analysis Tools; Risk Registers; Risk Monitoring and Reporting Tools	Tools and Protocols for Process Delivery	Identities; Job Descriptions; Roles; Functions; Actions & Access Control Lists	Nodes, Addresses and other Locators	Time Schedules; Clocks, Timers & Interrupts
SERVICE MANAGEMENT ARCHITECTURE	Service Delivery Management	Operational Risk Management	Process Delivery Management	Personnel Management	Management of Environment	Time Management
	Assurance of Operational Continuity & Excellence	Risk Assessment; Risk Monitoring & Reporting; Risk Treatment	Management & Support of Systems, Applications & Services	Account Provisioning; User Support Management	Management of Buildings, Sites, Platforms & Networks	Management of Calendar and Timetable

SABSA

Existen muchos enfoques diferentes para la arquitectura de seguridad. El enfoque del marco **SABSA** desarrolla una matriz de: Quién, Qué, Por qué, Dónde, Cuándo y Cómo para estructurar una arquitectura de seguridad.

Sherwood Applied Business Security Architecture (**SABSA**)

Columns shows aspects of the enterprise that can be described or modeled by each viewpoint

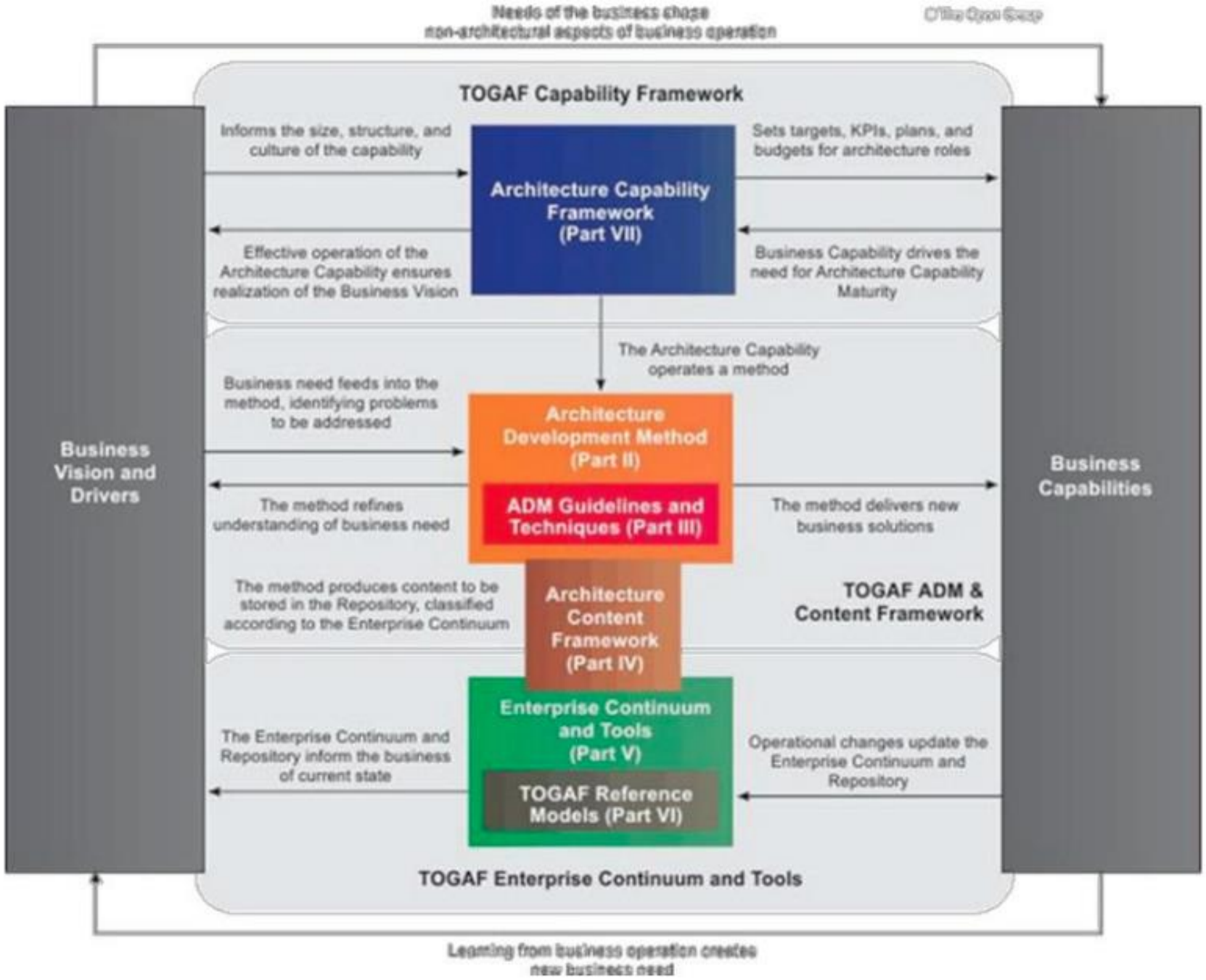
Rows represent various viewpoints to consider from the aspects

	Assets (What)	Motivation (Why)	Process (How)	People (Who)	Location (Where)	Time (When)
Contextual	The Business	Business Risk Model	Business Process Model	Business Organization and Relationships	Business Geography	Business Time Dependencies
Conceptual	Business Attributes Profile	Control Objectives	Security Strategies and Architecural Layering	Security Entity Model and Trust Framework	Security Domain Model	Security-related Lifetimes and Deadlines
Logical	Business Information Model	Security Policies	Security Services	Entity Schema and Privilege Profiles	Security Domain Definitions and Associations	Security Processing Cycle
Physical	Business Data Model	Security Rules, Practices and Procedures	Security Mechanisms	Users, Applications and the User Interface	Platform and Network Infrastructure	Control Structure Execution
Component	Detailed Data Structures	Security Standards	Security Products and Tools	Identities, Functions, Actions and ACLs	Processes, Nodes, Addresses and Protocols	Security Step Timing and Sequencing
Operational	Assurance of Operational Continuity	Operational Risk Management	Security Service Managment and Support	Application and User Management and Support	Security of Sites, Networks and Platforms	Security Operations Schedule

THE OPEN GROUP ARCHITECTURE FRAMEWORK (TOGAF)

The flexibility of TOGAF makes this framework effective for activities that range from **small development projects** to comprehensive **enterprise resource planning (ERP) systems**

TOGAF provides a structured approach for organizations seeking to **organize and manage the implementation of technology in the enterprise**



TOGAF FRAMEWORK

PART I (Introduction)

- It is a high-level introduction to the key concepts of EA and the TOGAF approach.
- It contains the definitions of terms used throughout TOGAF and release notes detailing the changes between this version and previous versions of TOGAF.

PART II (Architecture Development Method)

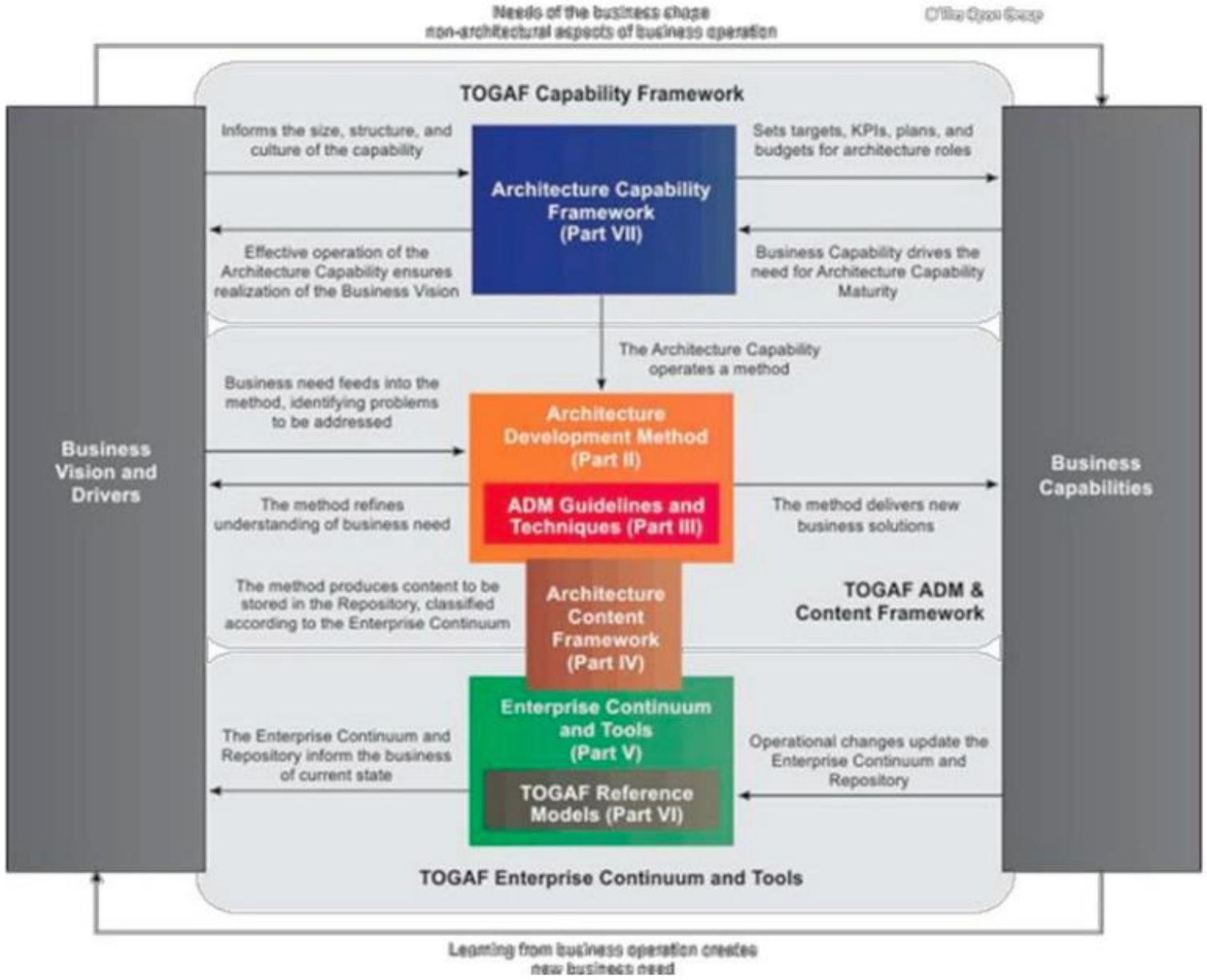
- It is the core of TOGAF.
- It describes the TOGAF Architecture Development Method (ADM)—a step-by-step approach to developing an EA.

PART III (ADM Guidelines and Techniques)

- This part contains a collection of guidelines and techniques available for use in applying TOGAF and the TOGAF ADM.

PART IV (Architecture Content Framework)

- This part describes the TOGAF content framework, including a structured meta-model for architectural artifacts, the use of reusable architecture building blocks, and an overview of typical architecture deliverables.



TOGAF FRAMEWORK

PART V (Enterprise Continuum and Tools)

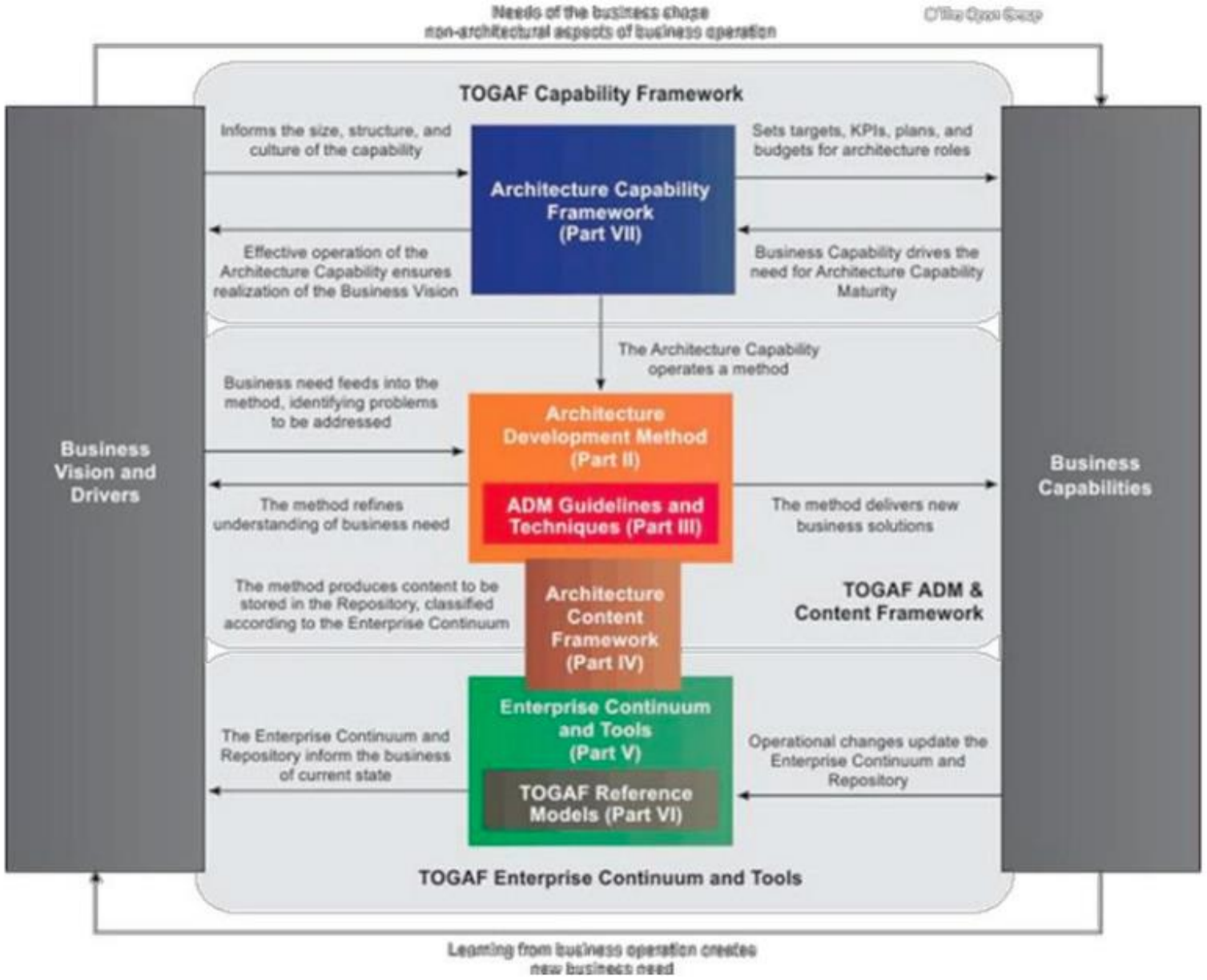
- This part discusses appropriate taxonomies and tools to categorize and store the outputs of architecture activity within an enterprise.

PART VI (TOGAF Reference Models)

- This part provides a selection of architectural reference models, including the TOGAF Foundation Architecture and the Integrated Information Infrastructure Reference Model (III-RM).

PART VII (Architecture Capability Framework)

- This part discusses the organization, processes, skills, roles, and responsibilities required to establish and operate an architecture function within an enterprise.



FEDERAL ENTERPRISE ARCHITECTURE FRAMEWORK (FEAF)

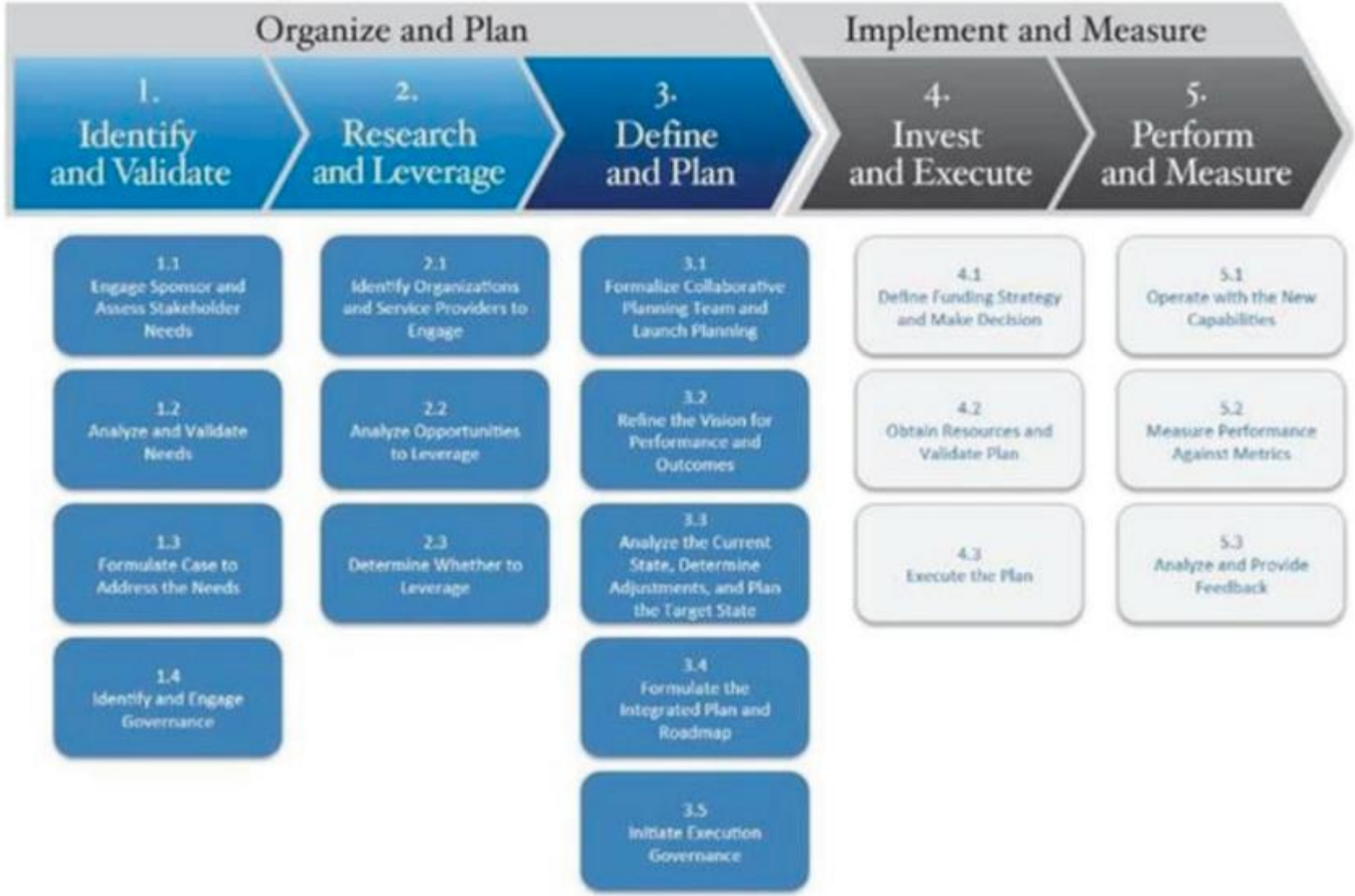
- FEAF v2 was developed for agencies of the US Federal Government
- This framework provides structure for connecting the organizations to exchange information.
- It helps agencies to describe the **current enterprise** in appropriate detail and identify **how the enterprise should look** in the future, so each organization can make plans to transition from the current state to the future state



FEDERAL ENTERPRISE ARCHITECTURE FRAMEWORK (FEAF)

- It consists of a set of interrelated reference models that describe the six sub-architecture domains in the framework:
  - Strategy
  - Business
  - Data
  - Applications
  - Infrastructure
  - Security

- It facilitates **cross-agency analysis** and the **identification of duplicative investments**, gaps, and **opportunities for collaboration** within and across agencies



Universidad del Rosario | Escuela de Ingeniería, Ciencia y Tecnología | MACC Matemáticas Aplicadas y Ciencias de la Computación | HINNT Hub de INNovación y Transferencia

GRACIAS



Ricardo Duitama

Profesional Ciberseguridad - MACC
Profesor catedra

ricardo.duitama@urosario.edu.co

@MACC_URosario @MACC.URosario macc_ur